

Privilege Escalation

(TA0004)

청주대학교 디지털보안학과 시스템보안실습

Privilege Escalation

- The adversary is **trying to gain higher-level permissions**.

Privilege Escalation

- Privilege Escalation consists of techniques that adversaries use to gain higher-level permissions on a system or network.
- Adversaries can often enter and explore a network with unprivileged access but *require elevated permissions to follow through on their objectives*.
- Common approaches are to *take advantage of system weaknesses, misconfigurations, and vulnerabilities*.

Privilege Escalation

- Examples of elevated access include:
 - SYSTEM/root level
 - local administrator
 - user account with admin-like access
 - user accounts with access to specific system or perform specific function
- These techniques often overlap with Persistence techniques, as OS features that let an adversary persist can execute in an elevated context.

Privilege Escalation: Techniques

- Abuse Elevation Control Mechanism
- Access Token Manipulation
- Account Manipulation
- Boot or Logon Autostart Execution
- Boot or Logon Initialization Scripts
- Create or Modify System Process
- Domain or Tenant Policy Modification
- Escape to Host
- Event Triggered Execution

Privilege Escalation: Techniques

- Exploitation for Privilege Escalation
- Hijack Execution Flow
- Process Injection
- Scheduled Task/Job
- Valid Accounts

Privilege Escalation: Exploitation for Privilege Escalation

● 과제2

- 2개의 VM인 CJU, Goal이 있다. 모두 OpenSSH 서버가 동작 중이며, 같은 네트워크에 있다.
- <https://drive.google.com/file/d/1xTphwknbCBe90zBYLmjX2vdqo-ok1a4F/view?usp=sharing>
- [다음 과정을 보이는 기술 블로그 포스트](#)를 작성하시오. (i, iii, v는 필수로 포함되어야 함)
 - i. CJU VM에 침투
 - ii. Privilege Escalation하기 위한 **Discovery**
 - iii. **CVE-2024-1086**를 이용하여 root 사용자로 **Privilege Escalation**
 - iv. CJU VM에서 Goal VM으로 Lateral Movement하기 위한 **Discovery** (**Discovery는 CJU VM에서 수행**)
 - v. CJU VM에서 Goal VM으로 Lateral Movement (**Lateral Movement는 CJU VM ⇒ Goal VM**)
- 에델바이스에는 개인 기술 블로그에서 **해당 실습을 보이는 포스트의 주소만** 올리시오.
 - i. 제목 : .
 - ii. 내용 : URL

Privilege Escalation: Exploitation for Privilege Escalation

- 과제2
 - 힌트 1
 - i. 최초 침투 시 VM 이름이 힌트입니다.

Privilege Escalation: Exploitation for Privilege Escalation

- Adversaries may exploit software vulnerabilities in an attempt to elevate privileges.
- Exploitation of a software vulnerability occurs when an adversary takes advantage of a programming error in a program, service, or within the operating system software or kernel itself to execute adversary-controlled code.
- Security constructs such as permission levels will often hinder access to information and use of certain techniques, so adversaries will likely need to perform privilege escalation to include use of software exploitation to circumvent those restrictions.

Privilege Escalation: Exploitation for Privilege Escalation

- When initially gaining access to a system, an adversary may be operating within a lower privileged process which will prevent them from accessing certain resources on the system.
- **Vulnerabilities may exist**, usually in operating system components and software commonly running at higher permissions, that can be exploited to gain higher levels of access on the system.
- This could enable someone to move from unprivileged or user level permissions to SYSTEM or root permissions depending on the component that is vulnerable.

Privilege Escalation: Exploitation for Privilege Escalation

- This could also enable an adversary to move from a virtualized environment, such as within a virtual machine or container, onto the underlying host.
- This may be a necessary step for an adversary compromising an endpoint system that has been properly configured and limits other privilege escalation methods.

Privilege Escalation: Exploitation for Privilege Escalation

- Adversaries may bring a signed vulnerable driver onto a compromised machine so that they can exploit the vulnerability to execute code in kernel mode.
- This process is sometimes referred to as Bring Your Own Vulnerable Driver (BYOVD).
- Adversaries may include the vulnerable driver with files delivered during Initial Access or download it to a compromised system via Ingress Tool Transfer or Lateral Tool Transfer.